

Apex POB — Go-Live & Handover

Deployment, accounts, backups, and security summary for production handover. Items marked «FILL IN» are operational decisions the operator/owner must complete.

1. Environments

	Dev	Production
Compose file	docker-compose.yml	docker-compose.prod.yml
Nginx config	frontend-react/nginx.conf	nginx/conf.d/pob.conf
TLS	none (HTTP)	443 (cert in nginx/certs/)
Env file	.env	.env.prod (gitignored)

Always deploy production with the prod compose — the dev stack is HTTP-only and source-mounted.

2. Production deploy

```
cd /path/to/POB_Version2.0
# 1. Provision TLS certs into nginx/certs/{fullchain,privkey}.pem
#   - DDNS hostname → Let's Encrypt (recommended)
#   - IP-only       → self-signed (browser warning) [currently in use]
# 2. Create and fill .env.prod (copy from .env.prod.example)
# 3. Bring up the stack
docker compose -f docker-compose.prod.yml up -d --build
# 4. Verify
curl -k https://<server>/health
```

Services started: postgres, redis, db-init, backend, celery-worker, celery-beat, frontend, nginx, db-backup, prometheus, grafana, alertmanager.

3. Network / access

- **Users:** https://<server> (443).
- **ADMS readers:** http://<server> (port 80, HTTP) — /iclock/* stays on 80; readers can't do TLS.
- **Monitoring (Grafana):** https://<server>/monitoring — restricted to private/VPN ranges.
- Gateway port-forwards public 80 / 443 → server. (443 only; 80 is required for ADMS.)
- Current public IP: 41.67.137.161; server LAN IP: 192.168.0.235. Recommendation: move to a **DDNS hostname** so a changing public IP doesn't break readers/cert.

4. Accounts & credentials

- Default admin: username admin (password **must be changed** at go-live).
- GLOBAL_ADMIN_PASSWORD (emergency superuser bypass) is set in .env.prod — store in your secrets manager. «FILL IN owner»
- Grafana admin user/password in .env.prod .

- **Do not commit** `.env.prod` or `nginx/certs/` (already gitignored). Recreate `.env.prod` on each server — it is intentionally never pushed to git.
- Database user `pob_user` currently uses a weak password — **rotate before/at go-live** («FILL IN»: `ALTER USER pob_user WITH PASSWORD ...` and update `.env.prod`).

5. Data migration (new server)

Docker volumes are per-machine; a fresh deploy starts empty. To migrate:

```
# OLD server
docker exec pob_postgres pg_dump -U pob_user -Fc pob_system > pob_db.dump
docker run --rm -v pob_version20_uploads_data:/d -v "$PWD":/b alpine tar czf
/b/uploads.tar.gz -C /d .
# transfer pob_db.dump, uploads.tar.gz, .env.prod, nginx/certs/ to NEW server
# NEW server
docker compose -f docker-compose.prod.yml up -d postgres
docker exec -i pob_postgres pg_restore -U pob_user -d pob_system --clean --if-exists
< pob_db.dump
# restore upload volumes, then: docker compose -f docker-compose.prod.yml up -d --
build
```

6. Backups

- `db-backup` service runs a daily `pg_dump` ; keeps 7 daily + 4 weekly + 3 monthly.
- Set `BACKUP_DIR` in `.env.prod` to a **NAS mount** for off-box storage (else local volume). «FILL IN NAS path»
- **Recommend:** verify a restore works, and confirm a retention/off-site policy.

7. Monitoring & alerting

- Prometheus + Grafana (`/monitoring`) + Alertmanager.
- Configure Alertmanager email (`ALERTMANAGER_*` in `.env.prod`) so BackendDown/DBDown alerts reach on-call. «FILL IN on-call email»

8. Security summary (client-facing)

- **Transport:** HTTPS/TLS for all user traffic; HSTS + CSP headers. (ADMS reader traffic is HTTP on 80 by device limitation, on the operator's controlled link.)
- **Authentication:** JWT access/refresh tokens with a strict type allowlist; optional **MFA**; login logout + rate limiting (nginx + app).
- **Authorisation:** role-based access control (RBAC); admin-only configuration/integration endpoints.
- **Secrets:** integration credentials encrypted at rest; config validators refuse insecure default secrets in production; outbound integration URLs validated (https-only, SSRF-guarded).
- **Auditing:** sensitive actions recorded in the audit log; per-sync logs for HR/finance exports.
- **Data integrity:** attendance computed from a single authoritative source; HR/finance exports are idempotent (no double-pay).
- Full internal assessment: `PRODUCTION_READINESS_DEEP_ANALYSIS.md` .

9. Outstanding go-live checklist

- ☐ DDNS hostname + Let's Encrypt cert (replace self-signed)

- ☐ Change `admin` password; set strong `GLOBAL_ADMIN_PASSWORD` ; rotate DB password
- ☐ Fill `.env.prod` notification channels (SMTP/SMS) — required for emergency alerts
- ☐ Set `DEVICE_SCAN_SUBNETS` (for any same-LAN readers); verify `GET /api/device/network-diagnostics`
- ☐ Validate Business Central + SeamlessHR against vendor sandboxes (`docs/INTEGRATIONS.md`)
- ☐ Confirm backup destination + test restore
- ☐ Configure Alertmanager recipients
- ☐ Run the test suite on the release build (`docker exec pob_backend python -m pytest tests/`)